FORENSIC QUICK WINS IN RANSOMWARE IR

Marc Ströbel / phroxvs

AGENDA

- The usual ransomware IR-setup
- Top initial access vectors
- Network log analysis
- Lateral movement analysis without SIEM
- Signature based scanning
- Follow the ransomware trail
- Summary

THE USUAL RANSOMWARE IR-SETUP (1)

- victims are at least partially encrypted
  - System-level encryption: some systems may be unavailable
  - Hypervisor-level encryption: usually only DCs and internal pivot hosts survive

- pressing questions
  - is my cloud environment safe? M365 will happily be used ;-)
  - restore backup from which date?
  - what systems have to be replaced / upgraded / hardened / patched …

- While an entire rebuilt sometimes is an option (with large effort), forensic insights always help

THE USUAL RANSOMWARE IR-SETUP (2)

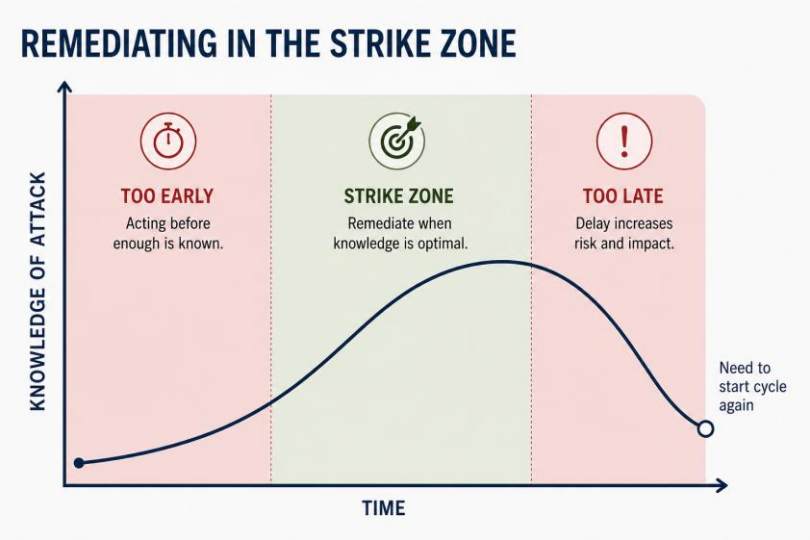
- no Endpoint Detection and Response deployed
  - quick option for infrastructure-wide analysis missing
  - traces / logs might be destroyed (particularly when hypervisor-level)

- no central log collection
  - analyzing lateral movement will be difficult

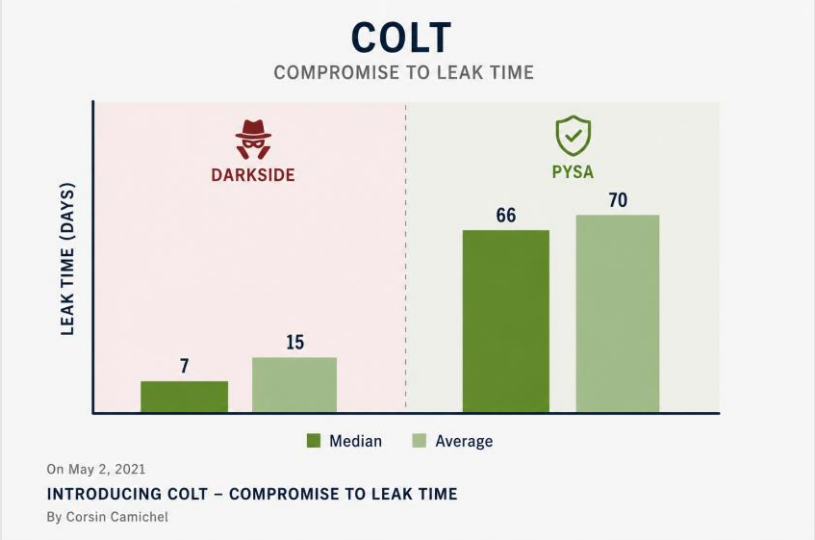
- sketchy volumes of Firewall log
  - conclusions for initial access and exfiltration might be difficult

RANSOMWARE VS. APT

- 2010er APTs weren't disruptive and allowed month long analysis



- Ransomware doesn't allow any time to waist



- but Ransomware also makes analysis easier
  - Most operators don't care about anti-forensics and use RDP / interactive sessions
  - As long as it runs it's a win – operators don't care about potential alerts

AGENDA

- The usual ransomware IR-setup
- **Top initial access vectors**
- Network log analysis
- Lateral movement analysis without SIEM
- Signature based scanning
- Follow the ransomware trail
- Summary

TOP INITIAL ACCESS VECTORS

- VPN account compromise
  - Single factor + credential stuffing
  - Business email compromise + bad initial MFA setup

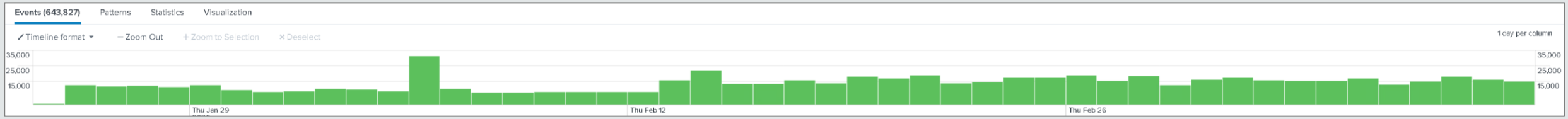
- Internet exploitable vulnerabilities / VPN box exploitation
  - Fortigate
  - Citrixbleed

- Phishing + remote access trojans

CREDENTIAL STUFFING

- Month long credential stuffing on a SonicWall single-factor SSL-VPN endpoint
  - ALIEN TXTBASE was used

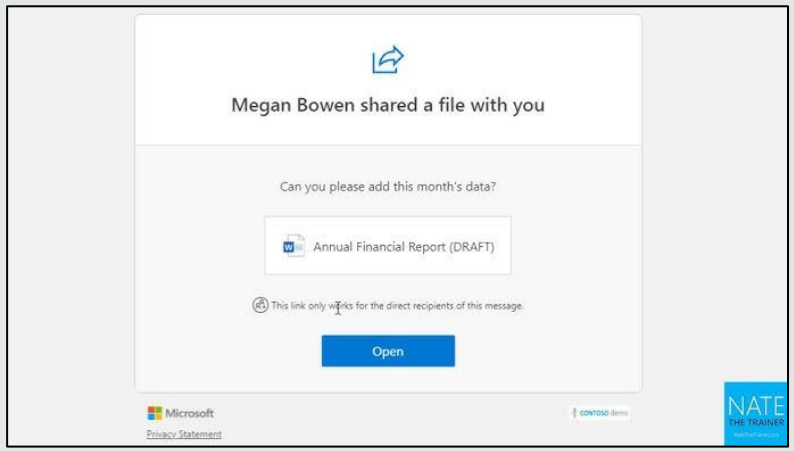


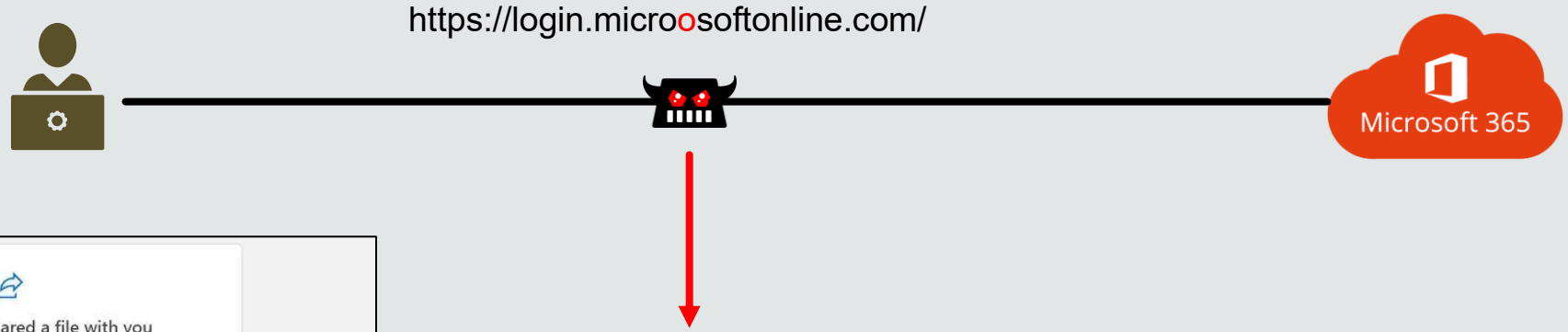


- Statistics:

Reason	Count
sslvpn_login_unknown_user	643683
sslvpn_login_permission_denied	143
web session login timeout	1

BUSINESS EMAIL COMPROMISE





username, password,
OAuth tokens, session

BEC + VPN BUNDLE IN ONEDRIVE

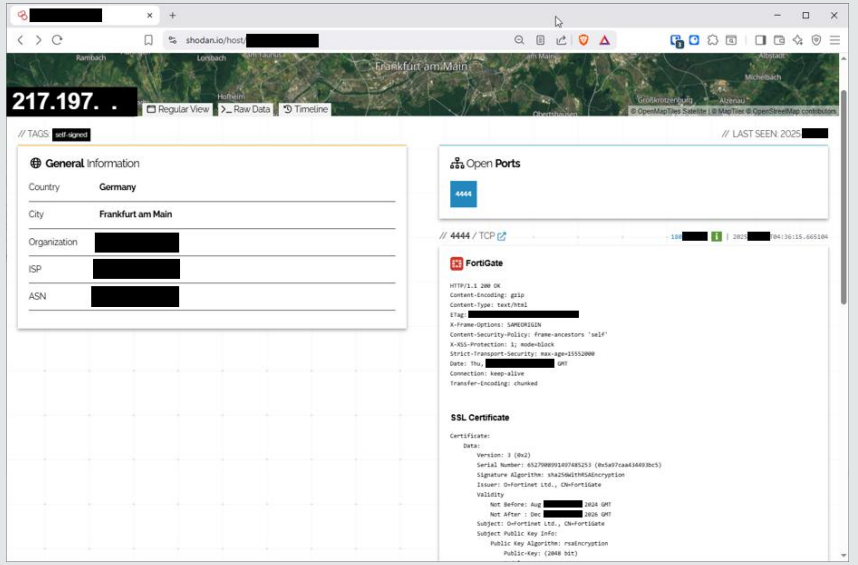
- IT department provided Sophos VPN client package (including private key) to its users via OneDrive

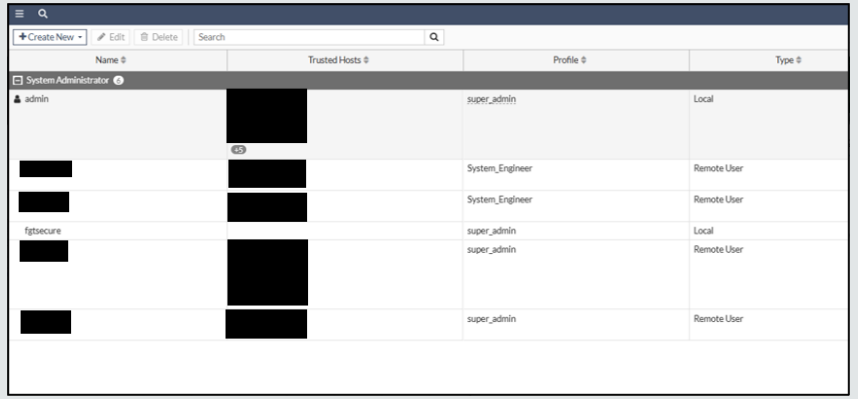
- M365 BEC turned into a ransomware operation:

_time	Workload	Operation	UserId	Source IP	Session	ObjectId
2025-12-07 10:40:25	OneDrive	FileAccessed	[redacted]onmicrosoft.com	4.208.178.90	00b7e639-9136-4faa-7cad-d0a71a040dbe	https://[redacted]sharepoint.com/personal/[redacted]/Documents/Dokumente/Distr/SophosSetup_[redacted]Clients.exe

VPN BOX EXPLOITATION

- FortiGate interface on 4444 public-available FortiGate
- FortiOS >4 months behind release
- FG-IR-24-535 exploited was
  - added admin “fgsecure”
  - added new SSL-VPN endpoint
- FG-IR-19-007 documents how to decrypt secrets for AD-integration user
  - e.g. https://github.com/saladandonionrings/cve-2019-6693







PHISHING + RAT

- Stories (often used together with social engineering)
  - Job application to HR
  - Job offer to single employees
  - Clickfix
  - Mailbombing

- Exemplary Mailbombing incident
  - E-Mail-Bombing of about > 100 emails per minute
  - Newsletter registrations etc. are abused
  - IT-helpdesk call
  - Quick-Assist remote control
  - CobaltStrike beacon shipped

AGENDA

- The usual ransomware IR-setup
- Top initial access vectors
- **Network log analysis**
- Lateral movement analysis without SIEM
- Signature based scanning
- Follow the ransomware trail
- Summary

FIREWALL LOG ANALYSIS

- 1.Choice: Cloud / VPN access and using existing analyst interface

- 2.Choice: Log export + Splunk + Ingest (+ AI chatbot for field extractions)
  - often slow and a lot of effort, since
    - every firewall box has different mechanisms for export
    - often exports get capped at 100k lines and admins don’t pay attention
    - super heterogonous log formats ☹

- Analysis Priority
  - VPN authentication logs
  - System logs
  - Traffic logs

VPN AUTHENTICATION LOG ANALYSIS

- VPN login bruteforce analysis
- VPN login IP reputation
  - e.g. with MaxMind and VirusTotal (https://github.com/Neo23x0/munin)
- VPN login multi-session / unlikely travel
- Compare VPN vs. Entra ID Sign-In Sources

FIREWALL SYSTEM LOGS

- Review installed version for existing vulnerabilities

- Review for activity like
  - Admin logins
  - Newly created users
  - Changed VPN profiles
  - Config changes
    - modified IP whitelisting
    - …

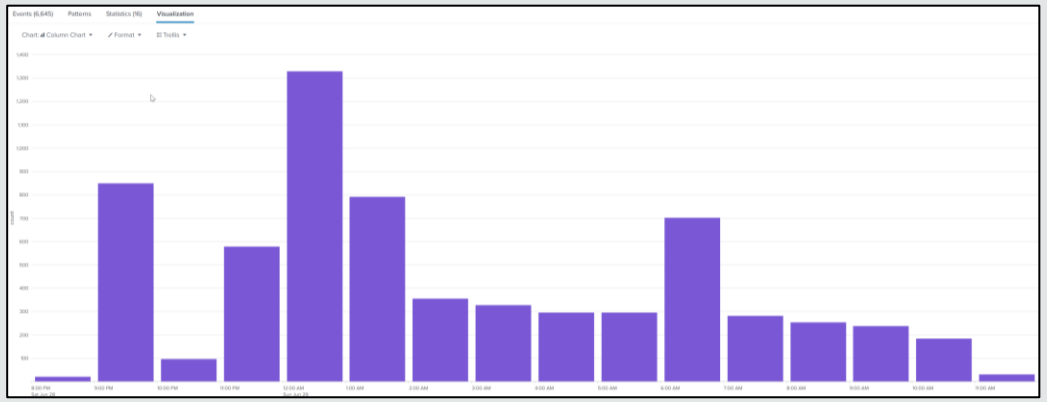
- Firewall vendor support can be really helpful to identify compromised devices

- Credentials from Belsen Group Leak abused for initial access on FortiGate

Time	Action	Device Name	Source IP	Message	Profile
2025-06-06 05:19	logout	FWFG001	209.145.52.118	Administrator adminAAA timed out on https	
2025-06-06 03:19	login	FWFG001	209.145.52.118	Administrator adminAAA logged in successfully from https	super_admin
2025-06-05 17:59	logout	FWFG001	209.145.52.118	Administrator adminAAA timed out on https	
2025-06-05 15:59	login	FWFG001	209.145.52.118	Administrator adminAAA logged in successfully from https	super_admin
2025-06-05 15:55	login	FWFG001	209.145.52.118	Administrator admin757 login failed from https because of invalid password	
2025-06-05 15:55	login	FWFG001	209.145.52.118	Administrator admin757 login failed from https because of invalid password	
2025-06-05 15:52	login	FWFG001	209.145.52.118	Administrator admin2 login failed from https because of invalid password	
2025-06-05 15:52	login	FWFG001	209.145.52.118	Administrator admin2 login failed from https because of invalid password	
2025-06-05 15:48	login	FWFG001	209.145.52.118	Administrator admin2 login failed from https because of invalid password	

TRAFFIC ANALYSIS

- VPN traffic patterns for administrative protocols
  - i.e. 22, 139, 445, 3389, 5985, 5986
- Compare DNS usage before and during incident
- activity bursts
  - Portscans
  - Netexec enumeration



Timestamp	Src	Src Port	Src Zone	Dst	Dst Port	Dst Zone	Action	Rec	Send
2025-11-26 15:27	172.16.255.3	20980	Sophos VPN Pool	192.168.20.253	3389	VLAN Server	Allow	260 B	200 B
2025-11-26 16:50	172.16.255.3	29414	Sophos VPN Pool	192.168.20.253	3389	VLAN Server	Allow	260 B	200 B
2025-11-27 15:41	192.168.20.14	52264	VLAN Server	192.168.43.253	3389	VLAN Server	Allow	260 B	200 B
2025-11-27 15:56	192.168.20.14	49648	VLAN Server	192.168.26.253	3389	VLAN Clients	Allow	260 B	200 B
2025-11-27 19:25	192.168.0.1	62533	VLAN Server	192.168.20.253	3389	VLAN Server	Allow	152 B	120 B
2025-11-27 19:32	192.168.0.1	59907	VLAN Server	192.168.43.253	3389	VLAN Server	Allow	152 B	120 B
2025-11-27 19:45	192.168.0.1	54223	VLAN Server	192.168.26.253	3389	VLAN Clients	Allow	152 B	120 B
2025-11-28 13:49	172.16.255.7	56739	Sophos VPN Pool	192.168.20.253	3389	VLAN Server	Allow	260 B	200 B
2025-11-28 17:42	10.0.100.12	61991	Storage-Cluster	10.0.100.254	3389	Storage-Cluster Gateway	Allow	260 B	200 B

AGENDA

- The usual ransomware IR-setup
- Top initial access vectors
- Network log analysis
- **Lateral movement analysis without SIEM**
- Signature based scanning
- Follow the ransomware trail
- Summary

CLASSIC ANTIVIRUS

- When a central AV log is available, details can give an analysis fast-track:
  - timestamp
  - compromised asset
  - compromised user
  - additional TTPs

Timestamp	Category	Cause	Computer Name	User	IP Address	Process Name
2026-08-31 08:34	Antivirus	MSIL/Riskware.Certify.E	ta126	NT AUTHORITY\SYSTEM	192.168.38.23	C:\Windows\System32\PING.EXE
2026-08-31 08:13	Antivirus	MSIL/Riskware.Certify.E	ta126	comp.local\usr	192.168.38.23	C:\Windows\System32\PING.EXE
2026-08-30 13:28	Antivirus	MSIL/Riskware.Rubeus.A	ta126	comp.local\usr	192.168.38.23	C:\Windows\System32\PING.EXE

USER ACCESS LOGGING (1)

- starting with Windows Servers 2012, User Access Log (UAL) record user requests to local services

- Really interesting on Domain Controllers and Fileservers
  - Authentication log with Username, IP address and Computer name
  - Authentication log with IP address and Computer name

- According to KPMG blog post these logs are written for following services
  - Active Directory Certificate Services (AD CS)
  - Active Directory Domain Services
  - Active Directory Rights Management Services (AD RMS)
  - BranchCache
  - Domain Name System (DNS)
  - Dynamic Host Configuration Protocol (DHCP)
  - Fax Server
  - File Services
  - File Transfer Protocol (FTP) Server
  - Hyper-V
  - Web Server (IIS)
  - Microsoft Message Queue (MSMQ) Services
  - Network Policy and Access Services
  - Print and Document Services
  - Routing and Remote Access Service (RRAS)
  - Windows Deployment Services (WDS)
  - Windows Server Update Services (WSUS)

USER ACCESS LOGGING (2)

- Domain Controller computer account authenticates from different IP than localhost / configured IP => Active Directory compromise

2026-01-01T00:00:01.019Z	Account: comp.local\dc01$ Source IP address: 10.10.28.33 Service identifier: {ad495fc3-0eaa-413d-ba7d-8b13fa7ec598} Service name: Active Directory Domain Services …	2026-05-21T125148_20…

- Follow lateral movement of compromised accounts

2026-02-14T22:07:13.998Z	Account: comp.local\adadm Source IP address: 172.28.0.27 Service identifier: {10a9226f-50ee-49d8-a393-9a501d47ce04} Service name: File Server Total accesses: 1 Ten…	2026-05-21T125148_20…
2026-02-14T22:12:49.031Z	Account: comp.local\adadm Source IP address: 10.20.8.1 Service identifier: {ad495fc3-0eaa-413d-ba7d-8b13fa7ec598} Service name: Active Directory Domain Services T…	2026-05-21T125148_20…
2026-02-14T22:12:49.344Z	Account: comp.local\adadm Source IP address: ::1 Service identifier: {10a9226f-50ee-49d8-a393-9a501d47ce04} Service name: File Server Total accesses: 3 Tenant identi…	2026-05-21T125148_20…
2026-02-14T22:12:50.064Z	Account: comp.local\adadm Source IP address: 10.20.8.1 Service identifier: {10a9226f-50ee-49d8-a393-9a501d47ce04} Service name: File Server Total accesses: 4 Tenan…	2026-05-21T123210_20…
2026-02-14T22:37:03.612Z	Account: comp.local\adadm Source IP address: ::1 Service identifier: {10a9226f-50ee-49d8-a393-9a501d47ce04} Service name: File Server Total accesses: 3 Tenant identi…	2026-05-21T125148_20…
2026-02-14T22:37:04.139Z	Account: comp.local\adadm Source IP address: 10.20.8.1 Service identifier: {10a9226f-50ee-49d8-a393-9a501d47ce04} Service name: File Server Total accesses: 4 Tenan…	2026-05-21T123210_20…
2026-02-14T22:37:04.777Z	Account: comp.local\adadm Source IP address: 10.20.8.1 Service identifier: {ad495fc3-0eaa-413d-ba7d-8b13fa7ec598} Service name: Active Directory Domain Services T…	2026-05-21T125148_20…

DNS LOGS ON DOMAIN CONTROLLERS

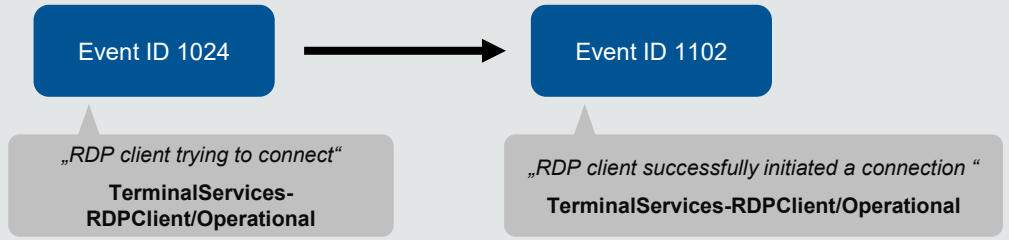
- Windows Event Log
  - Microsoft-Windows-DNS-Server-Service
- DNS debugging (if enabled)
  - C:\Windows\System32\dns\dns.log

- Indicators
  - Hick-ups in DNS-C2 channel might cause Event-ID 5504
    - DNS_EVENT_INVALID_PACKET_DOMAIN_NAME
  - If analytical events were switched on
    - DNS and IP reputation
  - Watch out for TXT DNS records and base64-encoded domain names

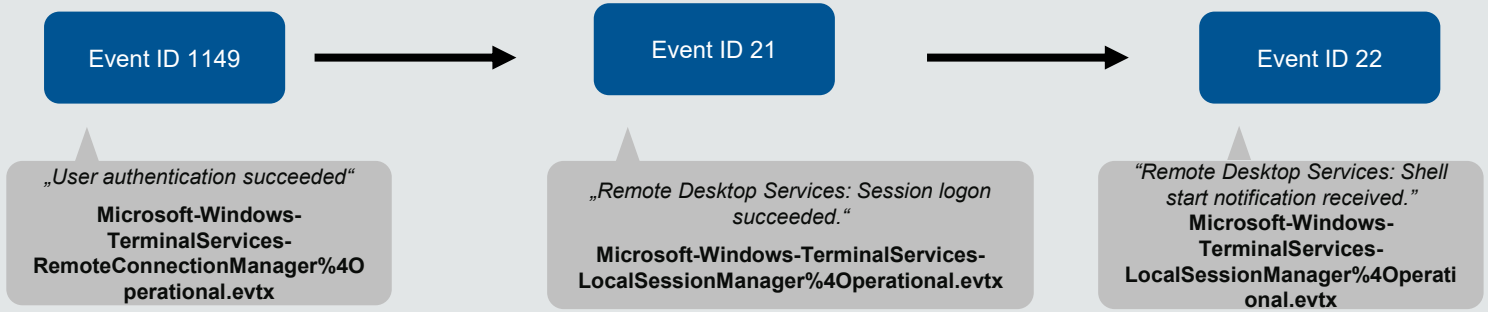
REMOTE DESKTOP EVENT LOG

- Due to *_normally_* infrequent use RDP logs are long living
  - Source machine
    - TerminalServicesRDPClient
  - Target machine
    - Microsoft-Windows-TerminalServices-RemoteConnectionManager
    - Microsoft-Windows-TerminalServices-LocalSessionManager
- Jonathon Poling wrote a nice article about the log flow

- RDP events on source system



- RDP events on target system



DEFENDER SUPPORT LOGS

- Even in passive mode or as a simple AntiVirus, the default installed Defender engine can provide valuable insights
  - Malware detections
  - Runtime information of the exact point in time
    - Accessed DLLs
    - Hashes
    - Process Hierachy

- Diagnostic logs in C:\ProgramData\Microsoft\Windows Defender\Support\ are created on activity
  - e.g. MPDetection-<YYYYMMDD-hhmmss>.log

- are collect in KAPE SANSTriage-Target

```
515 Scan ID:{9B4F2A17-63C5-4E8D-B2A9-7F1D4C8E3B62}
516 Scan Source:6
517 Start Time:04-14-2026 04:57:27
518 End Time:04-14-2026 04:57:40
519 Explicit resource to scan
520 Resource Schema:file
521 Resource Path:C:\ProgramData\libcef.dll
522 Result Count:1
523 Threat Name:Trojan:Win32/Bearfoos.A!ml
524 ID:2147731250
525 Severity:5
526 Number of Resources:1
527 Resource Schema:file
528 Resource Path:C:\ProgramData\libcef.dll
529 Extended Info - SigSeq:000026678f682746
530 Extended Info - SigSha:c9059de812513386d0544e75712f4af447ac1707
531 End Scan
```

AGENDA

- The usual ransomware IR-setup
- Top initial access vectors
- Network log analysis
- Lateral movement analysis without SIEM
- **Signature based scanning**
- Follow the ransomware trail
- Summary

SIGNATURE BASED ANALYSIS

Priorities

- Terminal servers / VDI
- Roaming profiles disk
- if possible all servers
- client endpoints: high effort, few results

- YARA Forge
  - https://yarahq.github.io/

- Sigma
  - https://github.com/SigmaHQ/sigma

- Nextron Valhalla
  - valhalla.nextron-systems.com
  - Demo key allows access to ~30% of signatures

- What to look out for
  - Defender operational events 1116 and 1117 (Sigma Rule)
  - RDP login from localhost (Sigma Rule)
  - Security login events with default Windows computer names like DESKTOP- (Windows client) or WIN- (Windows Servers)
  - Specific rules for C2 frameworks or hack tools, some good are
    - Sliver C2 Implant Activity Pattern (Sigma Rule)
    - Impacket (Sigma Rule) or smbexec.py services (Sigma Rule)
    - CobaltStrike in memory rules (Yara Rule)
    - Calls of DLL exports with rundll32.exe by ordinal (Sigma Rule)

TIMELINE FROM AN AKIRA INCIDENT (THOR ONLY)

Timestamp	Activity	System	Source	Account	Comment
2025-10-08 16:34		esx-srv-host3.company-intern.de			Last legitimate action of ESXi SSH: SSH disabled
2025-10-30 15:21	Credential Access	SRV-APP1			Local password dump with RegDump tool
2025-10-30 15:22	Credential Access	SRV-FIN3			Local password dump with RegDump tool
2025-10-30 15:22	Credential Access	SRV-APP2			Local password dump with RegDump tool
2025-10-30 15:22	Credential Access	SRV-ERP3			Local password dump with RegDump tool
2025-10-30 15:22	Credential Access	SRV-HR2			Local password dump with RegDump tool
2025-10-30 15:22	Credential Access	SRV-DAT1			Local password dump with RegDump tool
2025-10-30 15:26	Lateral Movement	SRV-BCK2		SRV-BCK2\Administrator	Remote Desktop Login
2025-10-30 15:30	Persistence	SRV-DC3		company-INTERN\Administrador	New Domain Admin created
2025-10-30 15:31	Persistence	SRV-DC3		company-INTERN\Administrat0r	New Domain Admin created
2025-10-30 16:04	Lateral Movement	esx-srv-host3.company-intern.de			ESXi SSH enabled
2025-10-30 16:06	Lateral Movement	esx-srv-host3.company-intern.de	SRV-ERP3	root	root login from attacker (DHCP VPN IP)
2025-10-30 16:19	Impact	esx-srv-host3.company-intern.de			Encryption started
2025-10-30 17:47		esx-srv-host3.company-intern.de	SRV-ERP3	root	root session of attacker closed

AGENDA

- The usual ransomware IR-setup
- Top initial access vectors
- Network log analysis
- Lateral movement analysis without SIEM
- Signature based scanning
- **Follow the ransomware trail**
- Summary

FOLLOW THE BREADCRUMBS – STARTING POINT

SYSTEM-LEVEL ENCRYPTION

- Signature scan / KAPE acquisition of all systems

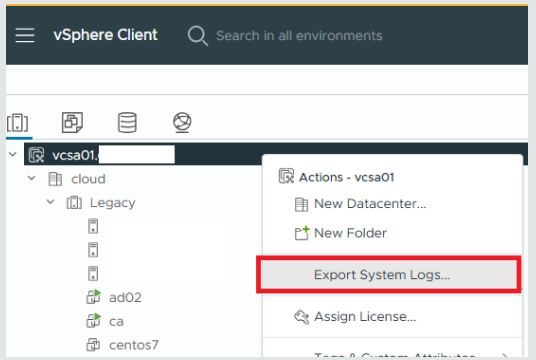
HYPERVISOR-LEVEL ENCRYPTION

- Start with Hypervisor logs and if necessary continue with full-disk

- Hyper-V = “normal” Windows workflow (KAPE + Full-disk)
- Proxmox = “normal” Linux workflow (Triage + Full-disk)
- VMware = vCenter / ESX diagnostics + Full-disk (maybe)

VMWARE DIAGNOSTICS / DISSECT

- Approach
  - Acqurie diagnostics via vCenter
  - Upload /var/log to Splunk
  - Analyze for SSH access





Name	Size	Packed Size
vmfs	55 710	68 608
var	34 101 403	34 133 504
usr	186 226	227 840
json	541 703	566 272
etc	4 212 314	4 379 648
commands	583 185 570	583 278 592
bootbank	282 445	282 624
vm-support-incident-key	1	512
README	2 437	2 560
errors-ignored.log	52 810	53 248
error.log	274	512
action.log	93 043	93 184

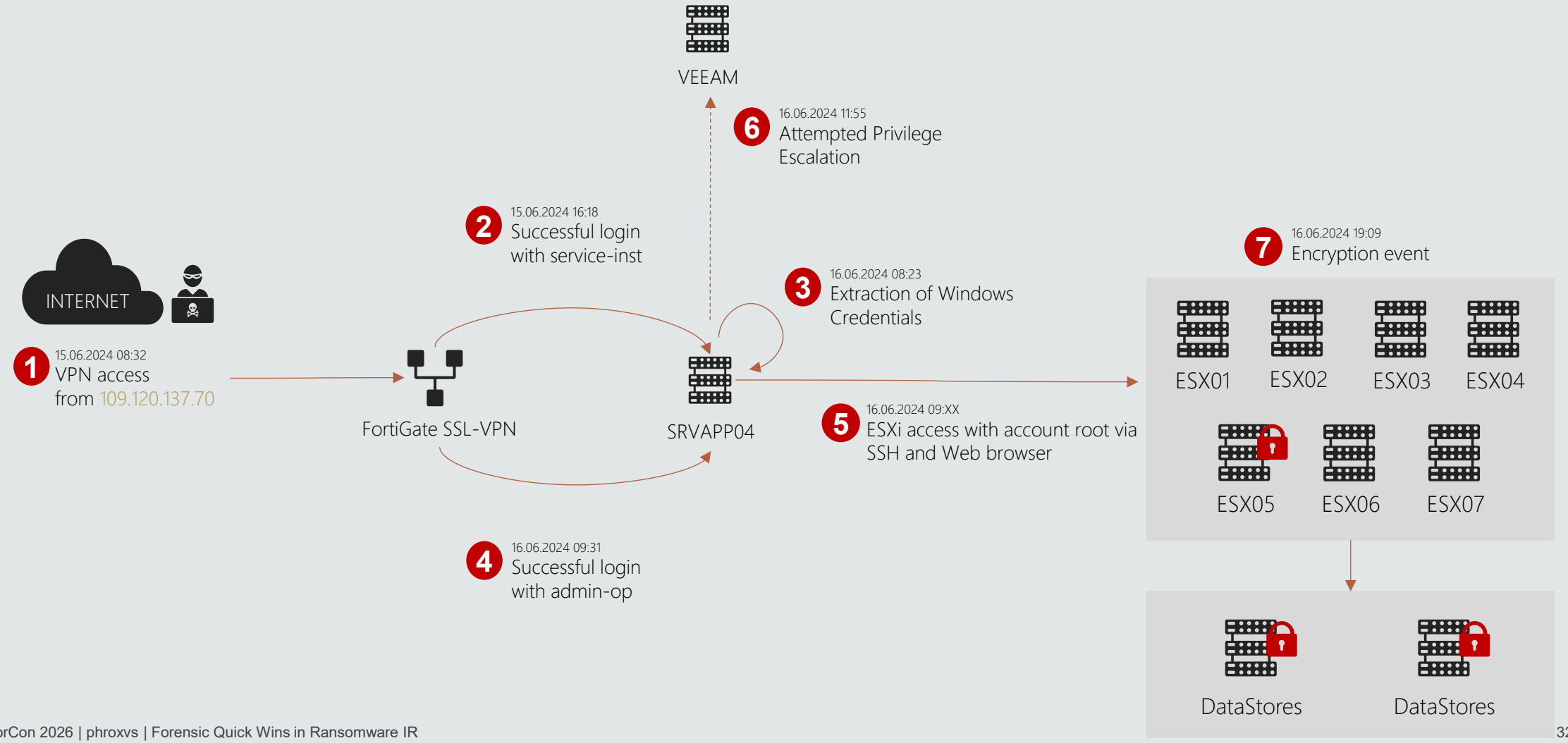
```
2025-10-31T12:25:36.961Z In(166) Hostd[2098820]: [Originator@6876 sub=Vimsvc.ha-eventmgr] Event 47864 : SSH session was opened for 'root@192.168.130.113'.
```

- Raw VMFS filesystems can be analyzed with Fox-Its' dissect
  - dissect.target.filesystems.vmfs has VMFS defition and allows target-query / target-shell operations

FOLLOW THE BREADCRUMBS – LATERAL MOVEMENT

- When available: use local and Domain Controller Security.evtx to track movement of compromised accounts
- Use Unified Access Logs
- Use RemoteDesktop event logs
- Analyze traffic of Pivot-hosts in firewall logs, try to find uncommon traffic patterns

INVESTIGATION RESULT



AGENDA

- The usual ransomware IR-setup
- Top initial access vectors
- Network log analysis
- Lateral movement analysis without SIEM
- Signature based scanning
- Follow the ransomware trail
- **Summary**

ANSWERING THE PRESSING QUESTIONS

- what systems have to be replaced / upgraded / hardened / patched …?
  - Defined by intrusion chain, lateral movement results and compromised assets

- restore backup from which date?
  - When possible restore systems from a point in time before initial access
  - For all other systems: clean-source install + migrate data + compromise scan + EDR

- is my cloud environment safe?
  - Yeah. Well. Perform a Microsoft 365 assessment.

MICROSOFT 365 ASSESSMENT

- Review Entra ID configuration, users and roles

- Focus on
  - Administrative Roles
  - Administrative users with on-premises sync
  - ServicePrincipal Review
  - Sign-Ins
  - User modification activity during ransomware timeframe (in particular MFA)

- Dirk Jans' RoadTools are really helpful (https://github.com/dirkjanm/roadtools)

LESSONS LEARNED

- Don’t waste any time during Firewall log acquisition

- System level encryption: deploy solution for victim independent evidence acquisition
  - EDR with triage package (e.g. PaloAlto Cortex)
  - KAPE provisioning and upload to dedicated S3-Bucket
  - Velociraptor

- Hypervisor-level encryption: Get somebody on-site

- Entra Global Reader + Security Reader should be included in your default requirements – can help during IR

THANKS